

Conducting a Risk Assessment of an Access Control System (3e)

Access Control and Identity Management, Third Edition - Lab 02

Student:

Ahmad Barakat

Email:

abarakat@ku.edu

Time on Task:

Progress:

100%

Report Generated: Tuesday, February 11, 2025 at 2:41 PM

Guided Exercises

Part 1: Research Risk Assessment Standards

4. **Compare** the requirements for access control systems in the PCI DSS to those in the HIPAA Security Rule. **Describe** the level of detail found in each standard and how each standard might be easier and more challenging to meet compared with the other.

They both establish access control requirements but differ in their level of detail, and flexibility.

PCI DSS: Restrict access, identify and authenticate, restrict physical access.

explicit mandates on multi-factor authentication and password policies.

HIPAA (Section 164.312):

Access control standard, some controls are required.

Part 2: Conduct a Risk Assessment

1. Conduct a risk analysis of this environment using the version of PCI DSS that you downloaded in Part 1 of this lab. **Document** at least five control gaps that exist in the environment. You may make assumptions about information not provided in this scenario, if necessary.

1. Generic accounts for cashiers
2. No multi-factor Authentication
3. Inadequate password complexity
4. No audit trail logging for POS activities
5. Lack of physical security controls for POS terminals.

Conducting a Risk Assessment of an Access Control System (3e)

Access Control and Identity Management, Third Edition - Lab 02

2. Identify controls that will mitigate each of the five deficiencies you identified in the previous step. **Create** a prioritized list of these actions.

1. Unique user accounts as high priority under PCI DSS requirements 2. MFA for all users as high priority 3. require complex passwords, including upper, lower case, and special characters and numbers, medium priority. 4. enable audit logging, high priority because of PCI DSS requirements. 5. Monitor and log physical access, low priority.

Challenge Exercise

1. What risk assessment standard would be the best approach for evaluating this system?
Depending on the system, you may use one of the standards already discussed in this lab or identify an alternative standard more appropriate for your environment. **Provide** a brief description of the system, **identify** the standard that you used and **describe** why it is appropriate for the system.

RevolutionEHR is a system commonly used in the optometry field. I am constantly using it every day. Our security compliance is with HIPAA as standard. This is appropriate to implement safeguards on client data and access control.

2. Conduct a risk assessment of the system against those standards to the best of your ability. If you are not familiar with the detailed workings of the systems, you may make assumptions to facilitate your risk assessment. **Create a list** of the gaps that exist between the system and the standard you used.

There is a strong password implementation and unique account for each user. However, they are all saved and you can log into whichever one you choose. Due to this, I strongly recommend a Multi-factor authenticator. That way it ensures you are logging into that account right then and there. I would also recommend real time monitoring of audit logs for potential security risks.

3. **Develop a prioritized list** of risk mitigation activities which, if followed, would address the issues raised in your gap analysis from step 2.

Implementing MFA would ensure only the authorized user is accessing the account in that moment. Especially for users with sensitive access to prevent unauthorized logins, for example Doctors. Real-time monitoring of audit logs would detect unauthorized access or suspicious activity, so adjusting to this will identify potential security risks and respond quicker.